

# The State of AI Tool and Agent Sprawl, 2026

## A Locked 250-Target Publication Cohort on Approval Proof, Deployment Signal, and Governance Evidence

- Report ID: ai-tool-sprawl-v2-2026
- Version: v2.1
- Run ID: sprawl-v2-top250-20260508a
- Cohort basis: locked 250-target publication cohort from internal/repos-v2-publication-250.md
- Campaign design: deterministic baseline, public-repository cohort, one repo per owner, clone-sourced scan artifacts
- Wrkr commit pin: 9134c3cf2ab903905babf5a38aa29e1526928bc7 (9134c3c)
- Prepared by Centre for AI Security and Integrity (CAISI). Contact: [david@caisi.dev](mailto:david@caisi.dev). Full artifacts: [github.com/Clyra-AI/safety](https://github.com/Clyra-AI/safety).

## Authorship and Affiliation

David Ahmann - Head of Cloud, Data and AI Platforms at CDW Canada ([LinkedIn](#)) Talgat Ryshmanov - Principal DevSecOps Consultant at Adaptavist ([LinkedIn](#))

## About CAISI

The Centre for AI Security and Integrity (CAISI) publishes independent, reproducible research on AI governance. Every headline number in this manuscript maps to machine-generated artifacts and deterministic queries in the repository.

This report measures what a locked public GitHub cohort exposes about AI tools, agent declarations, deployment evidence, approval posture, and control-aligned governance artifacts. It does not claim visibility into private repositories, production credentials, or internal runtime paths that are not exposed in public materials.

## Executive Summary

This publication replacement is based on a fully locked 250-target public cohort scanned from local clones. The cohort preserves the intended publication mix: 125 AI-native repositories, 75 developer-platform repositories, and 50 security-platform repositories. The run validates in strict full mode and uses refreshed detector logic from the current wrkr pin.

The strongest result is not that public repositories hide all deployment signal. They do not. In this cohort, **229 of 250 targets (91.6%)** exposed at least one declared agent and **220 of 250 (88.0%)** exposed at least one deployed-agent signal. The gap is elsewhere: **all 222 detected agents were missing at least one declared binding**, **136 of 250 targets (54.4%)** did not clear the deterministic verifiable evidence threshold, and non-source tools outside the baseline-approved set still outnumbered baseline-approved tools **5.64:1**.

The public compliance signal is also thin. **226 of 250 targets (90.4%)** showed an EU AI Act Article 50 transparency-proxy gap. Across the 249 targets that emitted framework rollups, average deterministic proxy coverage remained **33.33% for EU AI Act**, **0% for SOC 2**, and **0% for PCI DSS**. These are readiness proxies, not legal conclusions.

One methodological note matters. A single target, Yeachan-Heo/oh-my-c-laudecode, hit a parser failure in wrkr and was carried fail-closed into the aggregate with zero posture counts and no framework rollup rows. The cohort denominator remains 250 because the target stayed in scope and the failure handling is part of the measured pipeline behavior.

## Key Findings (At a Glance)

- Targets with declared agents: 91.6% (229/250)
- Average declared agents per target: 8.89
- Targets with deployed-agent signal: 88.0% (220/250)
- Declared agents with incomplete bindings: 100% (2222/2222)
- Targets without verifiable governance evidence: 54.4% (136/250)
- Not-baseline-approved to baseline-approved tool ratio: 5.64:1 (1845/327)
- Targets with Article 50 transparency-proxy gap: 90.4% (226/250)
- Targets with write-capable agents detected in public artifacts: 6.4% (16/250)
- Targets with exec-capable agents detected in public artifacts: 6.8% (17/250)
- Targets with credential-access agents detected in public artifacts: 18.0% (45/250)

## Headline Integrity Block

All headline claims in this manuscript map to one immutable publication artifact package.

- Run ID: sprawl-v2-top250-20260508a
- Target cohort file:

internal/repos-v2-publication-250.md

- Claim artifact:

runs/tool-sprawl/sprawl-v2-top250-20260508a/artifacts/claims-finalized-v2.json

- Aggregate artifact:

runs/tool-sprawl/sprawl-v2-top250-20260508a/agg/campaign-summary-v2.json

| Key | Headline number | Denominator                        |
|-----|-----------------|------------------------------------|
| H1  | 5.64            | baseline-approved non-source tools |
| H2  | 91.6            | targets scanned                    |
| H3  | 8.89            | targets scanned                    |
| H4  | 88.0            | targets scanned                    |
| H5  | 100             | declared agents                    |
| H6  | 54.4            | targets scanned                    |
| H7  | 90.4            | targets scanned                    |
| H8  | 250             | targets scanned                    |

Claim-key map:

- H1 = sprawl\_v2\_not\_baseline\_approved\_to\_approved\_ratio
- H2 = sprawl\_v2\_orgs\_with\_agents\_pct
- H3 = sprawl\_v2\_avg\_agents\_per\_org
- H4 = sprawl\_v2\_orgs\_with\_deployed\_agents\_pct
- H5 = sprawl\_v2\_agents\_missing\_bindings\_pct
- H6 = sprawl\_v2\_orgs\_without\_verifiable\_evidence\_pct
- H7 = sprawl\_v2\_article50\_gap\_prevalence\_pct
- H8 = sprawl\_v2\_orgs\_scanned

Deterministic query map:

```
H1 jq '.campaign.metrics.not_baseline_approved_to_approved_ratio'
H2 jq '.campaign.metrics.orgs_with_agents_pct'
H3 jq '.campaign.metrics.avg_agents_per_org'
H4 jq '.campaign.metrics.orgs_with_deployed_agents_pct'
H5 jq '.campaign.metrics.agents_missing_bindings_pct'
H6 jq '.campaign.metrics.orgs_without_verifiable_evidence_pct'
H7 jq '.campaign.metrics.article50_gap_prevalence_pct'
H8 jq '.campaign.metrics.orgs_scanned'
```

Additional supporting claims, including write-capable, exec-capable, credential-access, and attack-path prevalence, are mapped in runs/tool-sprawl/sprawl-v2-top250-20260508a/artifacts/claims-finalized-v2.json.

## 1) What We Scanned

The frozen publication cohort for this report contains 250 public owner/repo targets selected under the v2 publication profile with one repository per owner.

Locked cohort composition:

| Cohort             | Targets |
|--------------------|---------|
| AI-native          | 125     |
| Developer platform | 75      |
| Security platform  | 50      |
| Total              | 250     |

Collection ran against local clones rather than live API retrieval so the publication denominator stayed fixed through execution.

Headline scope facts:

| Measure                                  | Value |
|------------------------------------------|-------|
| Targets scanned                          | 250   |
| Headline-scope tools                     | 2172  |
| Baseline-approved tools                  | 327   |
| Not-baseline-approved tools              | 1845  |
| Targets with at least one declared agent | 229   |
| Declared agents                          | 2222  |
| Targets with at least one deployed agent | 220   |
| Deployed agents detected                 | 1030  |

The report therefore measures a broad public agent and tool surface, not just a thin edge case subset.

## 2) Why This Matters for Software Delivery and AppSec

Public AI adoption signal only becomes operationally useful when it can be tied to delivery-relevant authority. AppSec does not need a generic count of AI mentions. It needs evidence about which repositories expose tool invocation, deployment markers, privilege indicators, approval posture, and proof quality.

This run shows that public repositories can expose significant AI and agent activity without exposing clean governance proof. The core gap is no longer "we cannot see deployment at all." The gap is that deployment signal, approval normalization, and binding completeness do not mature together.

That matters for security leadership because review pressure lands at the execution boundary. If a repository exposes agent deployment markers but does not expose durable tool, data, and auth bindings, then security and audit still lack a clean answer to what the agent can touch and under what control boundary.

## 3) Tool Approval Posture

Headline-scope tool results remain approval-heavy and proof-light.

| Tool approval posture                            | Count  |
|--------------------------------------------------|--------|
| Baseline-approved tools                          | 327    |
| Explicit-unapproved tools                        | 0      |
| Approval-unknown tools                           | 1845   |
| Not-baseline-approved tools                      | 1845   |
| Not-baseline-approved to baseline-approved ratio | 5.64:1 |

The ratio should still be read as an approval-proof gap, not as a danger score. There were no explicit-unapproved markers in headline scope. The measurable issue is that the system could not deterministically establish baseline approval for most detected non-source tools.

This is stronger than a documentation complaint. When approval evidence is not machine-readable, governance reporting becomes manual, exception handling becomes noisy, and assurance depends on memory instead of artifact continuity.

#### 4) Agent and Deployment Posture

The refreshed scanner materially changes the public deployment story. Declared agents are widespread, and deployed-agent signal is also widespread. What does not improve with that signal is binding completeness.

| Agent posture                      | Value           |
|------------------------------------|-----------------|
| Targets with declared agents       | 229/250 (91.6%) |
| Average declared agents per target | 8.89            |
| Targets with deployed-agent signal | 220/250 (88.0%) |
| Declared agents                    | 2222            |
| Deployed agents detected           | 1030            |
| Binding-complete agents            | 0               |
| Binding-incomplete agents          | 2222            |

The most important line in that table is still the binding result. Every detected agent was missing at least one declared binding, and most were missing all three tracked binding dimensions (tool, data, and auth).

In practical terms, the public repo surface is now rich enough to show deployment intent or deployment evidence in many targets. It is still too weak to support clean claims about fully bound, governable delivery actors.

#### 5) Privilege and Attack-Path Posture

Public repositories did expose some privilege-relevant agent signal in this cohort.

| Exposure qualifier                     | Value          |
|----------------------------------------|----------------|
| Targets with write-capable agents      | 16/250 (6.4%)  |
| Targets with exec-capable agents       | 17/250 (6.8%)  |
| Targets with credential-access agents  | 45/250 (18.0%) |
| Targets with agent-linked attack paths | 24/250 (9.6%)  |
| Targets with production-write agents   | 0/250 (0%)     |

These values are important because they show the public surface is not limited to harmless declarations. At the same time, they remain public-artifact measurements. A public zero on production-write does not prove internal safety. It shows only that the deterministic public artifact set did not expose production-write evidence under the current policy.

## 6) Governance Evidence and Regulatory Readiness

The strongest governance finding in this cohort is the evidence gap.

| Evidence posture                    | Count           |
|-------------------------------------|-----------------|
| verifiable evidence tier            | 114             |
| basic evidence tier                 | 136             |
| Targets without verifiable evidence | 136/250 (54.4%) |

More than half of the scanned targets exposed enough AI or agent signal to be in scope but not enough evidence to clear the deterministic verifiable threshold.

Regulatory outputs are deterministic readiness proxies, not legal conclusions. The run showed 226/250 targets (90.4%) with an Article 50 transparency-proxy gap. Framework rollups were emitted for 249 targets:

| Framework family | Average proxy coverage | Readout                                       |
|------------------|------------------------|-----------------------------------------------|
| EU AI Act        | 33.33%                 | effectively 1 of 3 proxy controls visible     |
| SOC 2            | 0%                     | no visible proxy coverage in public artifacts |
| PCI DSS          | 0%                     | no visible proxy coverage in public artifacts |

The run can therefore say something about public governance evidence for EU AI Act, SOC 2, and PCI DSS proxies. It does not support broader claims about frameworks that are not currently in the v2 headline-eligible mapping set.

The meaningful conclusion for AppSec and platform governance is that public AI and agent signals are common, but the evidence needed to support stronger control assertions remains sparse.

## 7) What the Report Proves

This report proves that, in a locked public 250-target cohort:

1. AI tool and agent adoption is broadly visible in public repositories.
2. Deployment evidence is often visible too.
3. Binding completeness is still absent from the public surface.
4. Approval evidence is much weaker than discovery.
5. Governance and regulatory proof posture remain materially incomplete.

That combination matters because it changes the interpretation burden. The strongest story is no longer "public repos barely show deployment." The strongest story is "public repos often show enough to trigger governance questions, but not enough to close them."

## 8) Recommendations

1. Track deployment evidence and binding completeness separately. Deployment markers are not enough to support clean authority claims.
2. Normalize approval evidence into machine-readable policy so detected tools can be resolved deterministically.
3. Require explicit tool, data, and auth binding disclosure for agents that can influence delivery paths.
4. Treat credential-access, write-capable, and exec-capable detections as escalation points for deeper review, not as complete risk statements.
5. Keep public proxy findings in the right lane. They are governance-readiness indicators, not substitutes for internal runtime review.

## 9) Methodology

The cohort uses the v2 deterministic-baseline pipeline and the frozen publication list in `internal/repos-v2-publication-250.md`. Source material came from `wrkr scan --json` runs against local clones of public repositories, one repository per owner.

Key methodological facts:

- Frozen publication cohort file: `internal/repos-v2-publication-250.md`
- Candidate ledger: `internal/repos-v2-publication-250_candidates.csv`
- Wrkr pin: `9134c3cf2ab903905babf5a38aa29e1526928bc7 (9134c3c)`
- Headline tool scope excludes `tool_type == "source_repo"`
- Framework families treated as headline-eligible in v2: EU AI Act, SOC 2, PCI DSS
- Aggregate artifact: `runs/tool-sprawl/sprawl-v2-top250-20260508a/agg/campaign-summary-v2.json`
- Appendix artifact: `runs/tool-sprawl/sprawl-v2-top250-20260508a/appendix/combined-appendix-v2.json`
- Calibration gold labels: `reports/ai-tool-sprawl-v2-2026/calibration/gold-labels.top250-20260508.json`

Validation status for this publication replacement:

- relaxed validation passed with `failures=0`
- strict full-lane validation passed with `failures=0`
- required threshold checks passed 6/6
- recommended threshold checks passed 11/11

Recommended calibration metrics for deployment, binding precision, and privilege recall remain advisory gaps in this publication package. They do not block strict full-lane publication under the current gate policy.

## 10) Appendix

Primary appendix artifacts for this manuscript:

- `runs/tool-sprawl/sprawl-v2-top250-20260508a/appendix/combined-appendix-v2.json`
- `runs/tool-sprawl/sprawl-v2-top250-20260508a/appendix/tool-inventory.csv`
- `runs/tool-sprawl/sprawl-v2-top250-20260508a/appendix/agent-inventory.csv`
- `runs/tool-sprawl/sprawl-v2-top250-20260508a/appendix/agent-privilege-map.csv`
- `runs/tool-sprawl/sprawl-v2-top250-20260508a/appendix/framework-rollups.csv`
- `runs/tool-sprawl/sprawl-v2-top250-20260508a/appendix/regulatory-gap-matrix-v2.csv`
- `runs/tool-sprawl/sprawl-v2-top250-20260508a/appendix/org-summary-v2.csv`

The run-local finalized claims and threshold outputs for this manuscript are:

- `runs/tool-sprawl/sprawl-v2-top250-20260508a/artifacts/claims-finalized-v2.json`
- `runs/tool-sprawl/sprawl-v2-top250-20260508a/artifacts/threshold-evaluation-v2.json`

## Limitations

- This is a public-repository study. It underexposes private runtime privilege, internal approval workflows, and production-connected behavior.
- One target failed scanner parsing and was carried fail-closed into aggregate outputs.
- Headline tool metrics exclude `source_repo` rows by design.
- Framework outputs are deterministic readiness proxies, not legal or audit conclusions.
- Public deployment evidence does not prove live runtime execution at the time of scan.

## Threats to Validity

- Visibility bias: public repositories reveal less than internal systems about runtime identities, secrets, and production authority.
- Detector-coverage bias: some frameworks, config conventions, and deployment patterns are easier to detect than others.
- Binding inference bias: `missing_bindings` measures missing declared bindings, not true runtime absence.
- Policy-mapping bias: tool approval and framework proxy results depend on the currently locked policy and mapping sets.

## Residual Risk

- Internal and private environments may have materially higher privilege and deployment risk than this public cohort exposed.
- Targets classified as basic evidence posture may still operate significant AI or agent workflows internally without public proof artifacts.
- Public 0% production-write results should not be interpreted as safety guarantees.

## Reproducibility Notes

- Run command used for this manuscript:

```
pipelines/sprawl/run_v2.sh \  
  --run-id sprawl-v2-top250-20260508a \  
  --lane full \  
  --purpose publication \  
  --targets-file internal/repos-v2-publication-250.md \  
  --max-targets 250 \  
  --scan-source clone \  
  --keep-clones
```

- Calibration command used for this manuscript:

```
pipelines/sprawl/calibrate_detectors_v2.sh \  
  --run-id sprawl-v2-top250-20260508a \  
  --gold-labels reports/ai-tool-sprawl-v2-2026/calibration/gold-labels.top250-20260508.json \  
  --strict
```

- Claim finalization command used for this manuscript:

```
pipelines/sprawl/finalize_claims_v2.sh \  
  --run-id sprawl-v2-top250-20260508a \  
  --update-ledger \  
  --validate \  
  --lane full \  
  --strict
```

- PDF build command:

```
pipelines/common/build_report_pdf.sh --report-dir reports/ai-tool-sprawl-v2-2026
```

This report is strongest as a public evidence and governance-readiness measurement. It is weaker as a direct runtime privilege study. That distinction is part of the result, not a presentation caveat.